

OTP Attack Analysis Report

Brute Force vs Collision-Based Attacks on Time-Limited OTPs

Generated: 2026-05-25T14:16:23

This report models and visualizes the risk of brute-force and collision-style attacks against a 10-character OTP over a 62-character alphabet, where the OTP changes every 5 minutes and no rate limiting or secondary authentication factor is enforced.

Table of Contents

1. Mathematical Foundations
2. Threat Model
3. Attack Model
4. Security Implications
5. Brute Force Scatter Plot
6. Collision Scatter Plot
7. Brute Force Surface Plot
8. Collision Surface Plot
9. Conclusions & Future Exploration

Mathematical Foundations

Keyspace for a 10-character password over 62 characters:

$$N = 62^{10} = 8.393e+17$$

Brute-force per-guess probability:

$$p_{bf} = 1 / N = 1.191e-18$$

Weak generator entropy: 40 bits

$$\text{Weak space size: } 2^E = 1.100e+12$$

Overlap factor (fraction of weak space overlapping strong outputs): 0.1

Collision per-guess probability:

$$p_{coll} = \text{overlap} / \text{weak_space} = 9.095e-14$$

Cumulative success probability after k independent attempts with per-guess success probability p is given by:

$$P(k) = 1 - (1 - p)^k.$$

Threat Model

This analysis assumes an attacker with the following capabilities:

- Unlimited OTP login attempts (no rate limiting).
- Ability to automate requests at high speed.
- Knowledge of OTP format and timing.
- Ability to exploit weak or biased OTP generation.

The defender is assumed to:

- Rely solely on OTP for authentication.
- Not enforce device binding or IP throttling.
- Not monitor for abnormal login velocity.
- Not enforce MFA or challenge-response mechanisms.

Under these assumptions, the system is vulnerable to both brute-force and collision-style attacks, with the latter being significantly more dangerous if the OTP generator exhibits entropy weaknesses.

Attack Model

We consider a 10-character OTP drawn from a 62-character alphabet (A-Z, a-z, 0-9). The OTP changes every 5 minutes, similar to a TOTP.

Brute-force attack:

- The attacker samples uniformly from the full keyspace.
- Per-guess success probability is $p_{bf} = 1 / 62^{10}$.
- Over a 5-minute window, the attacker can make many guesses, but the probability remains extremely small if the OTP is truly random.

Collision-style attack:

- The attacker uses a weaker generator with effective entropy E bits.
- The weak generator covers a space of size 2^E .
- Only a fraction of that space overlaps the true OTP distribution; this is modeled by an overlap factor f .
- Per-guess success probability is $p_{coll} = f / 2^E$.

If the OTP generator is biased or has structural weaknesses, a collision-style attack can be significantly more effective than naive brute force.

Security Implications

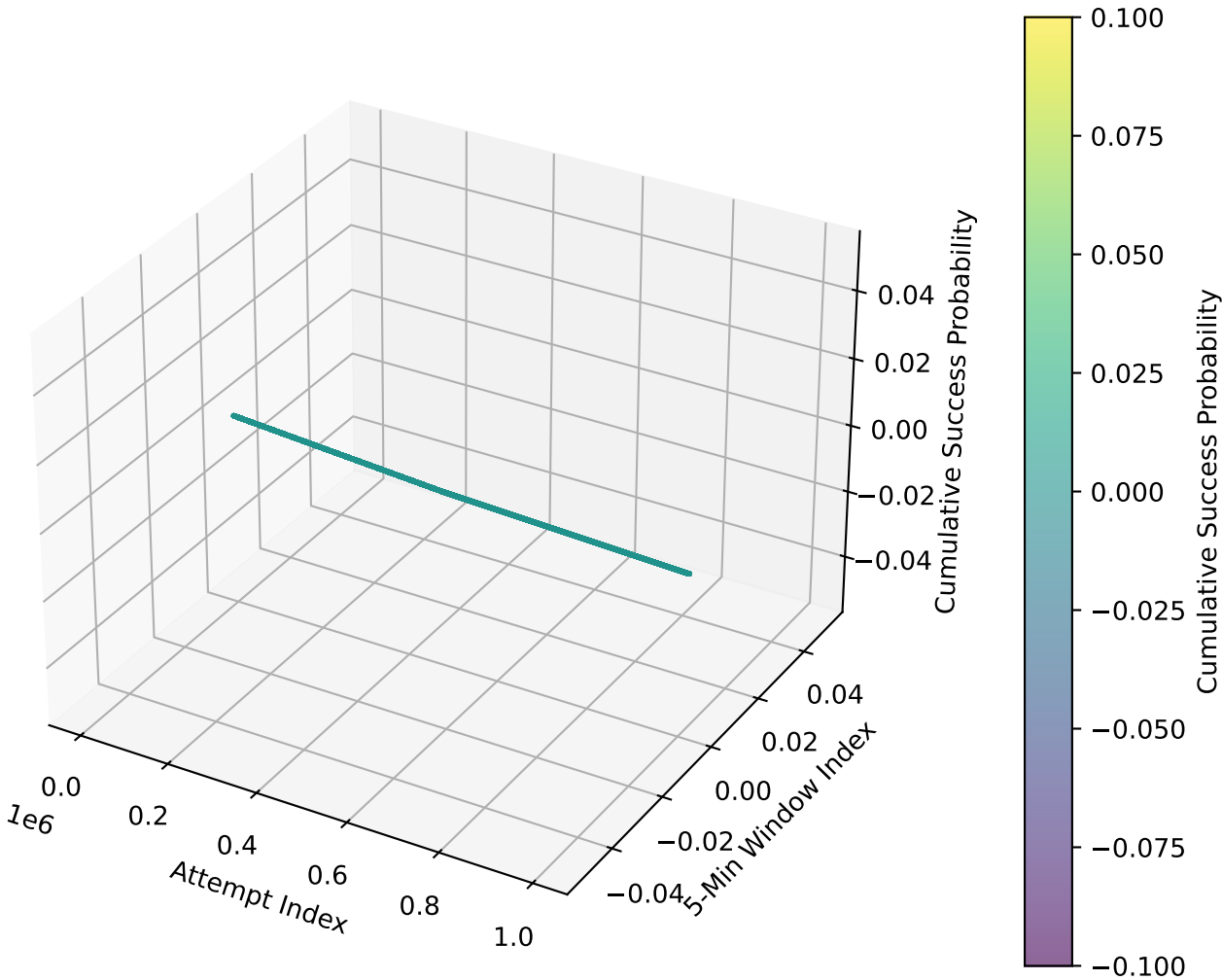
A system that allows unlimited OTP login attempts with no rate limiting is vulnerable to both brute-force and collision-style attacks. Even though the brute-force probability is extremely low, a weak or biased OTP generator can dramatically increase the attacker's success rate.

Single-factor OTP login is fundamentally unsafe because:

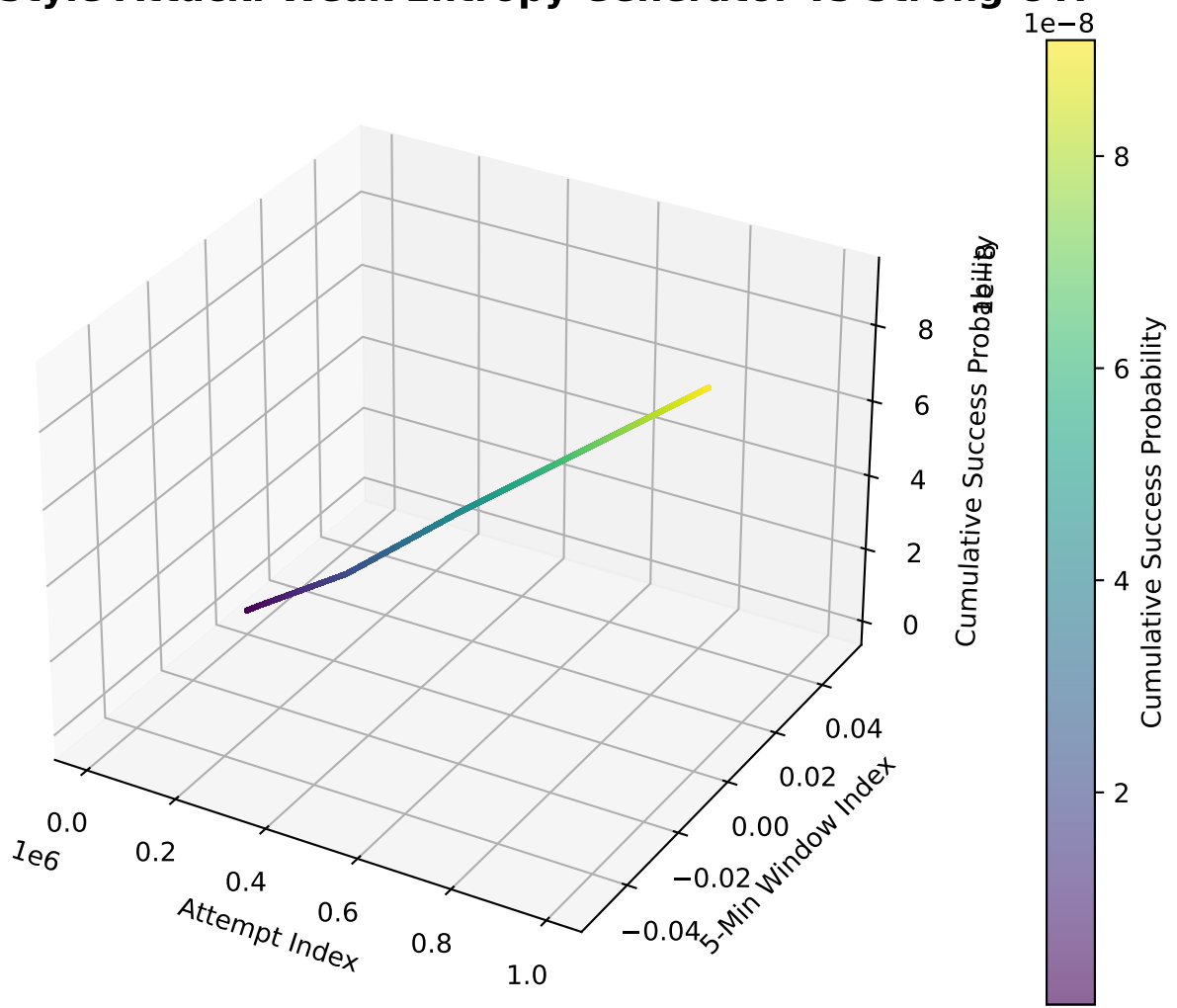
- OTPs are guessable values.
- No rate limiting allows unbounded attempts.
- No MFA means a single correct guess grants full access.
- Weak entropy or biased RNGs can be exploited.

Future exploration includes entropy leakage analysis, RNG bias detection, timing channels, and OTP clustering behavior.

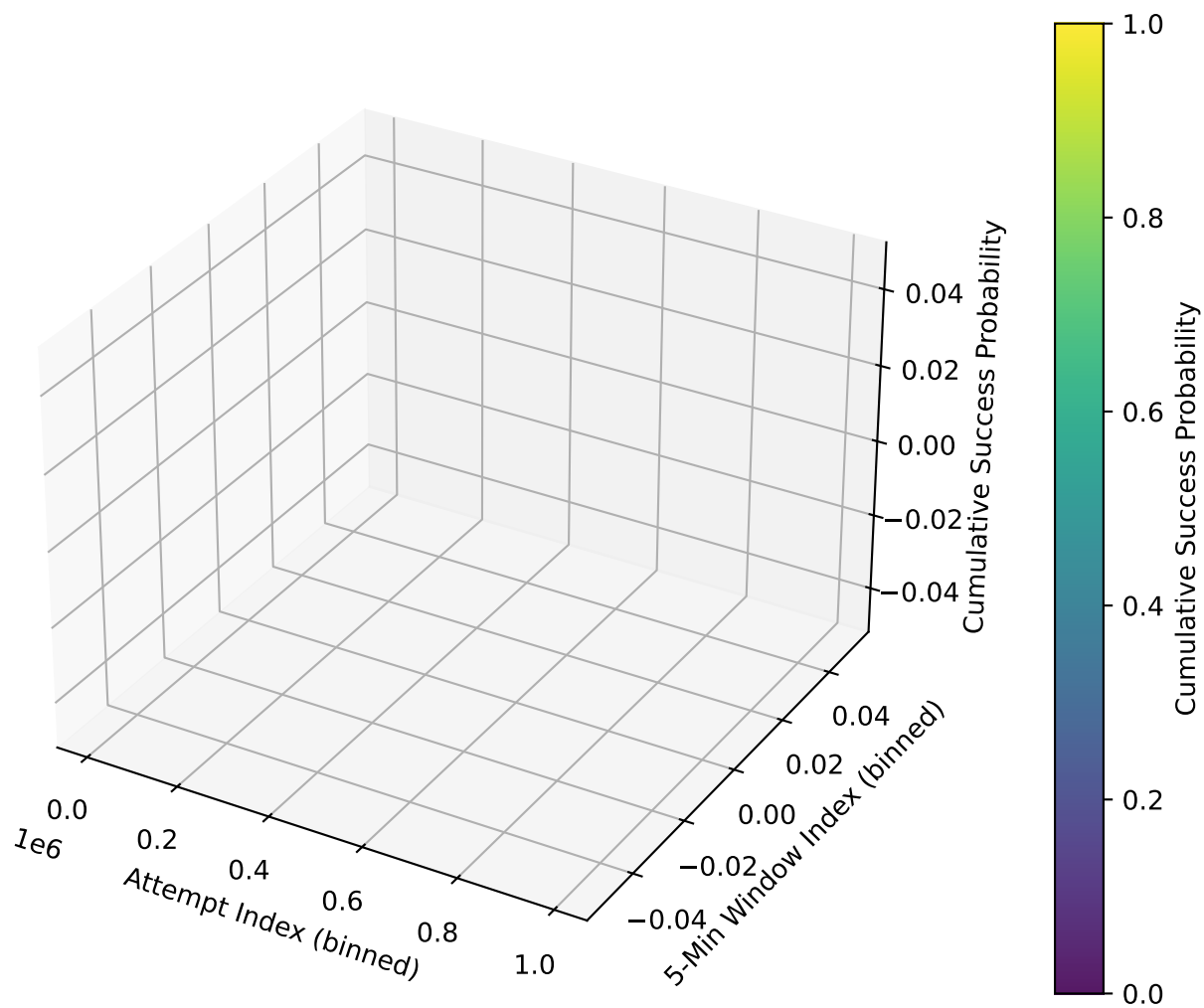
Brute Force Attack: 10-Character OTP, 62-Character Alphabet



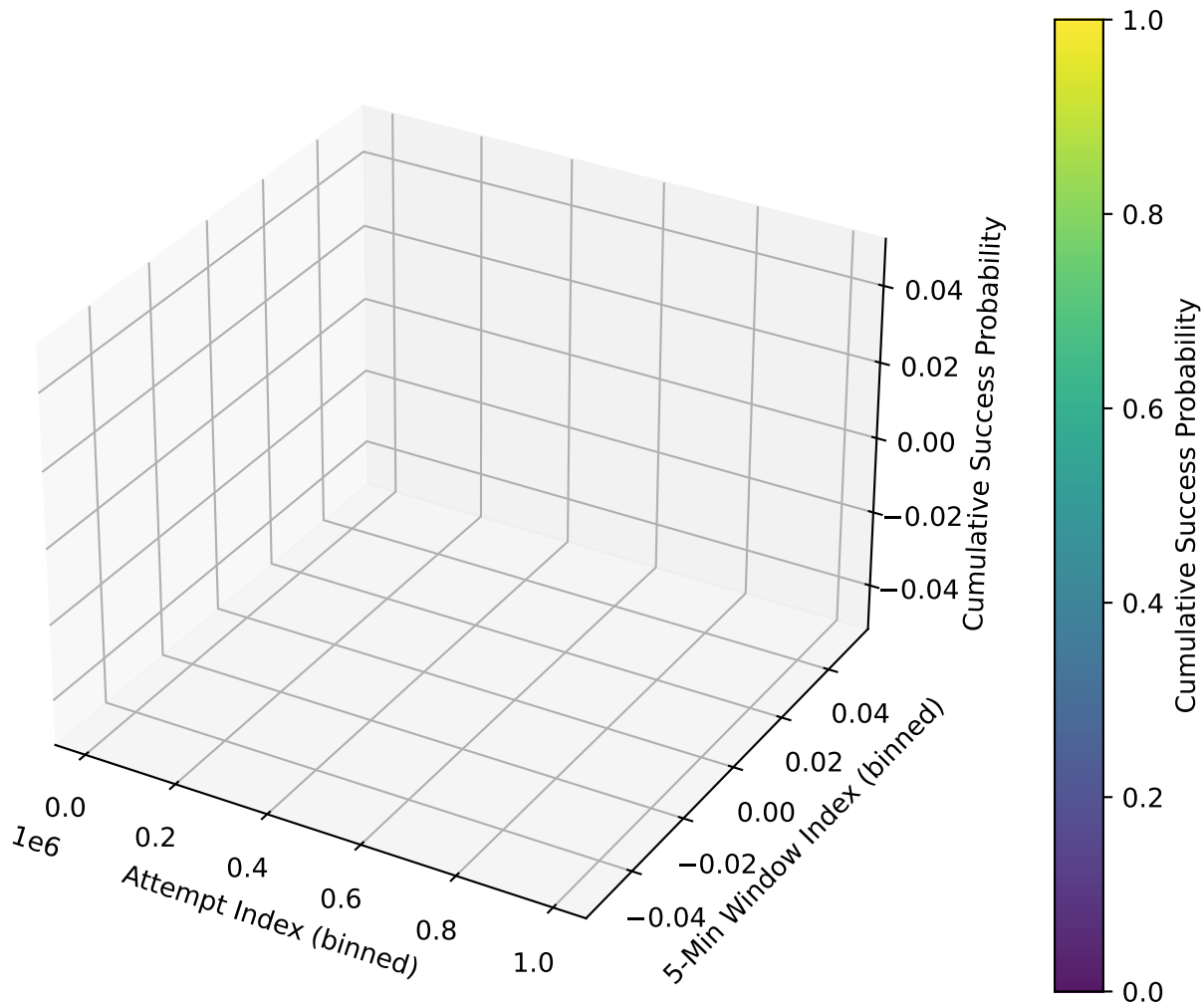
Collision-Style Attack: Weak Entropy Generator vs Strong OTP



Brute Force Cumulative Success Probability Surface



Collision-Style Cumulative Success Probability Surface



Conclusions & Future Exploration

This analysis demonstrates that single-factor OTP authentication is insufficient for protecting user accounts, especially when no rate limiting is enforced. Even with a large keyspace, the presence of a weak or biased OTP generator can drastically increase the probability of successful attacks.

Future exploration should include:

- Entropy leakage measurement.
- Statistical analysis of OTP distribution.
- RNG bias detection and clustering.
- Timing channel analysis.
- Modeling adversarial sampling strategies.
- Evaluating MFA and device-binding mitigations.

The evidence strongly supports migrating away from single-factor OTP authentication toward multi-factor, rate-limited, and device-bound authentication mechanisms.